Internet Security 1 (IntSec1)

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

2 Introduction to Cryptology

Prof. Dr. Andreas Steffen

Institute for Internet Technologies and Applications (ITA)

2 Introduction to Cryptology

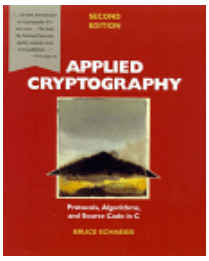
- Literature
- Basic terminology
- Principles of cryptanalysis
- Claude Shannon's cryptographic principles of confusion and diffusion
- Caesar monoalphabetik substitution cipher
- Vigenère polyalphabetic substitution cipher
- Transposition cipher
- Plain text redundancy
- Entropy (cryptographical strength) of passwords
- Perfect secrecy – the one-time pad
- Shannon's model of a secrecy system

Cryptography - Literature

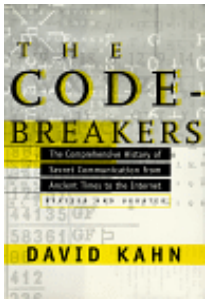
HSR
HOCHSCHULE FÜR TECHNIK
RAPPERSWIL

- Modern Cryptography
  - Bruce Schneier, "Applied Cryptography: Protocols, Algorithms, and Source Code in C, 2nd Edition", 784 pages, 1996, John Wiley & Sons, ISBN 0-471-11709-9

    http://www.counterpane.com



- History of Cryptography
  - David Kahn, "The Codebreakers: The Comprehensive History of Secret Communication from Ancient Times to the Internet", 1181 pages, 1996, Scribner Book Company, ISBN 0-684-83130-9



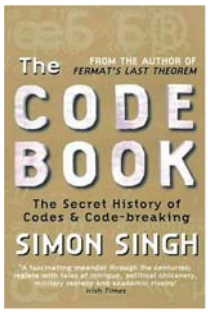
Cryptography - Literature (light)

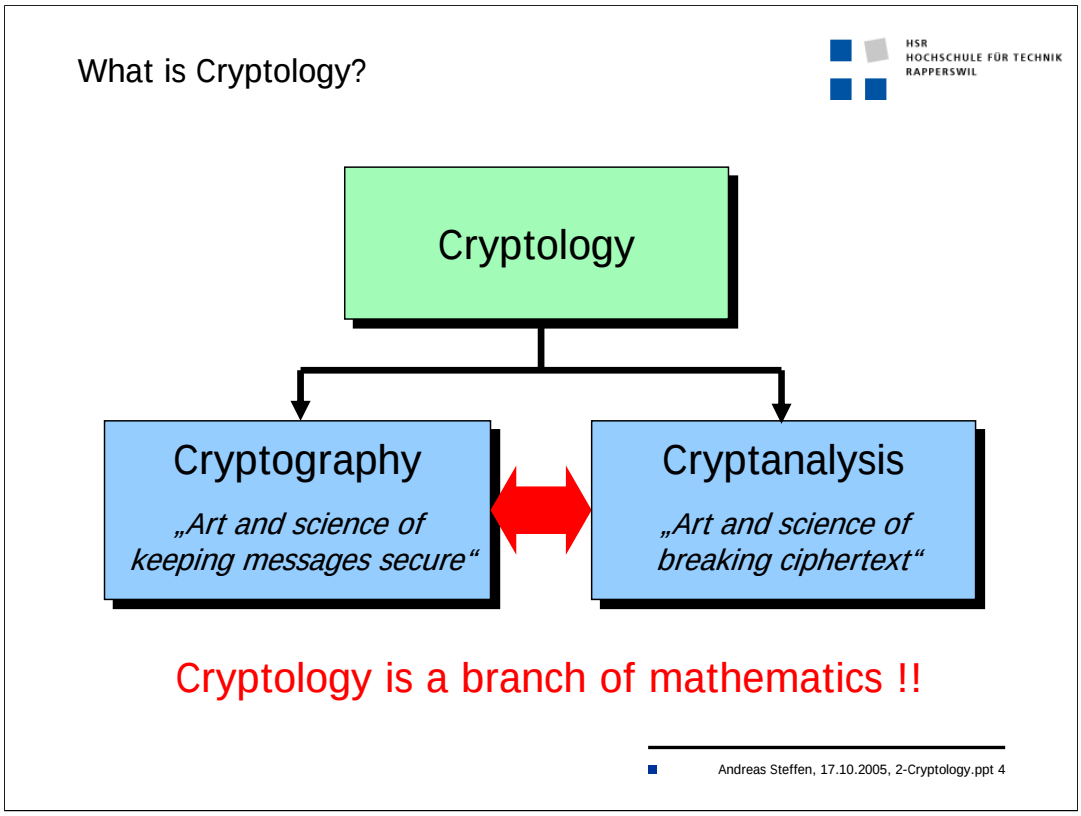
HSR
HOCHSCHULE FÜR TECHNIK
RAPPERSWIL

- Practical Cryptography
  - Niels Ferguson & Bruce Schneier, "Practical Cryptography", 410 pages, 2003, John Wiley & Sons, ISBN 0-471-22357-3



- The Code Book
  - Simon Singh, "The Code Book : The Science of Secrecy from Ancient Egypt to Quantum Cryptography", 402 pages, 2000, Fourth Estate, ISBN 1-857-02889-9

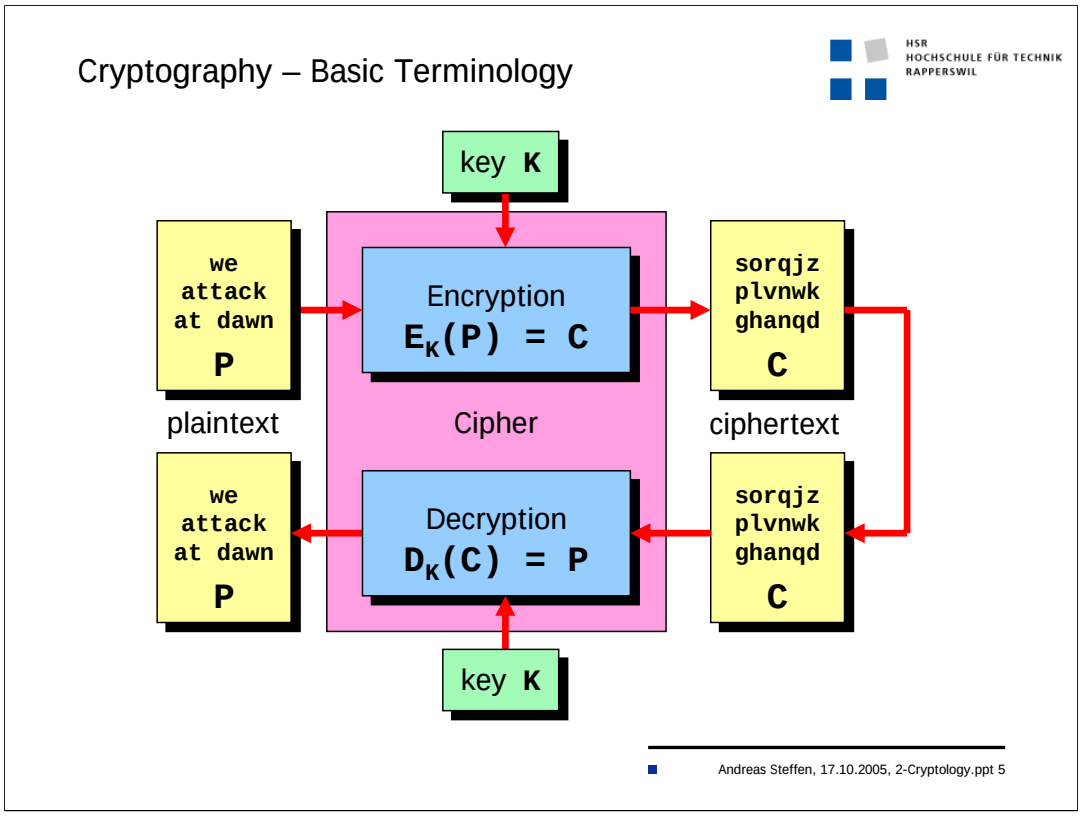




Cryptology

- The art and science of keeping messages secury is **cryptography**, and it is practiced by **cryptographers**.
- **Cryptanalysts** are practitioners of **cryptanalysis**, the art and science of breaking ciphertext; that is seeing through the disguise.
- The branch of mathematics encompassing both cryptography and cryptanalysis is **cryptology** an its practitioners are **cryptologists**.
- Modern cryptologists are generally trained in **theoretical mathematics** – they have to be.

Source: Bruce Schneier, „Applied Cryptography“, Second Edition, p. 1, John Wiley & Sons, 1996



Messages and Encryption

- A message is **plaintext** (sometimes called cleartext). The process of disguising a message in such a way as to hide its substance is called **encryption**.
- An encrypted message is **ciphertext**. The process of turning ciphertext back into plaintext is called **decryption**.

Algorithms and Keys

- A **cryptographic algorithm**, also called a **cipher**, is the mathematical function used for encryption and decryption.
- The security of a modern cryptographic algorithm is based on a secret **key**. This key might be any one of a large number of values. The range of possible key values is called the **keyspace**.
- Both encryption and decryption operations are dependent on the key K and this is denoted by the K subscript in the functions $E_K(P) = C$ and $D_K(C) = P$

Source: Bruce Schneier, „Applied Cryptography“, Second Edition, pp. 1..3, John Wiley & Sons, 1996

Cryptanalysis – Fundamental Assumptions

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

The security of a cipher should rely on the secrecy of the key only!

Auguste Kerckhoffs, „La Cryptographie militaire“, 1883

- Attacker knows every detail of the cryptographical algorithm
- Attacker is in possession of encryption / decryption equipment (HW machine or SW implementation)
- Attacker has access to an arbitrary number of plaintext / ciphertext pairs generated with the same (unknown) key.
- Strong cipher: Best attack should be brute force key search!

„La Cryptographie militaire“

- Author: Auguste Kerckhoffs, born 1835 at Nuth, Holland
- **Good cryptographic algorithms are found only through thorough cryptanalysis!**
- Kerckhoffs deduced the following **six requirements** for selecting usable field ciphers:

1) the system should be, if not theoretically unbreakable, unbreakable in practice
2) Compromise of the system should not inconvenience the correspondents
3) The key should be remembrable without notes and should be easily changeable
4) The cryptograms should be transmissible by telegraph
5) the apparatus or documents should be portable and operable by a single person
6) the systems should be easy, neither requiring knowledge of a long list of rules nor involving mental strain.

Cryptanalysis – Types of Attacks

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

- Ciphertext-Only Attack
  - Attacker knows ciphertext of several messages encrypted with the same key and/or several keys
  - Recover the plaintext of as many messages as possible or even better deduce the key (or keys)
- Known-Plaintext Attack
  - Known ciphertext / plaintext pair of several messages
  - Deduce the key or an algorithm to decrypt further messages
- Chosen-Plaintext Attack
  - Attacker can choose the plaintext that gets encrypted thereby potentially getting more information about the key
- Adaptive Chosen-Plaintext Attack
  - Attacker can choose a series of plaintexts, basing the choice on the result of previous encryption → differential cryptanalysis!

Differential Cryptanalysis

- Introduced in 1990 by Eli Biham and Adi Shamir, who used it to show that for certain classes of cryptographic algorithms an adaptive chosen plaintext attack existed that was much more efficient than brute force.
- Although potentially vulnerable, the „Data Encryption Standard“ (DES) was shown to be surprisingly resistant to differential cryptanalysis.
  - Why do the S-boxes contain exactly those optimal values that make such a differential attack as difficult as possible?
  - Why does DES use exactly 16 rounds, the minimum required to make the effort for differential cryptanalysis about the same as a brute force approach?

Answer: Because in the early 1970s the developers at IBM already knew about differential cryptanalysis!

IBM‘s Don Coppersmith wrote in 1992:

The design took advantage of certain cryptanalytic techiques, most prominently the technique of „differential cryptanalysis“, which were not known in the published literature. After discussions with the National Security Agency (NSA), it was decided that disclosure of the design considerations would reveal the technique of differential cryptanalysis, a powerful technique that can be used against many ciphers. This in turn would weaken the competitive advantage the United States enjoyed over other countries in the field of cryptography

National Security Agency (NSA)

- Created in 1952 by President Harry Truman with the mandate to listen in on and decode all foreign communications of interest to the security of the United States.
- Rumored to employ about 16‘000 people, among them about 2000 of the world‘s best mathematicians.

How to construct a Secure Cipher?

HSR
HOCHSCHULE FÜR TECHNIK
RAPPERSWIL

World War II German Enigma Machine



1 0 1 0 0 1 1 1 0 1 ...

Thomas Jefferson‘s Cipher Wheel



Andreas Steffen, 17.10.2005, 2-Cryptology.ppt 8

Thomas Jefferson‘s Cipher Wheel

- Thomas Jefferson was America‘s first Secretary of State under George Washington and invented his „wheel cypher“ either during 1790 to 1793 or during 1797 to 1800. He needed it to protect communications from England and France to the U.S. The device consisted of an iron spindle and a screw used to keep 36 distinct wooden wheels fixed in place. On each of the numbered wheels the 26 letters of the alphabet were engraved on the circumference in arbitrary order, so that no two cylinder had the same order. In order to encrypt a plain text, the letters were arranged on a single line by aligning the individual wheels accordingly. The cipher text could then be read off by selecting any other line of the cylinder.

- There are exactly 36! ways of mounting the 36 numbered wheels one after the other onto the spindle. Due to this large key space the Jefferson cipher was quite secure and was used from 1923 to 1942 in modified form by both U.S. Army and U.S. Navy to encrypt tactical information. Even after it was declared unsecure in 1942, the field cipher remained in use in the U.S. Navy for quite some more years.

  Source: David Kahn, „The Codebreakers“

The German Enigma

- The Enigma was an electromechanical rotor machine implementing a polyalphabetic substitution cipher. It was used by the German Wehrmacht and Kriegsmarine to encrypt most of its communications. Due to several weaknesses both in the implementation and the usage of the machine, the cipher could be broken by the British at Bletchley Park.

Claude Shannon 1916 - 2001

The Father of Information Theory

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

«Vater des Bit» gestorben

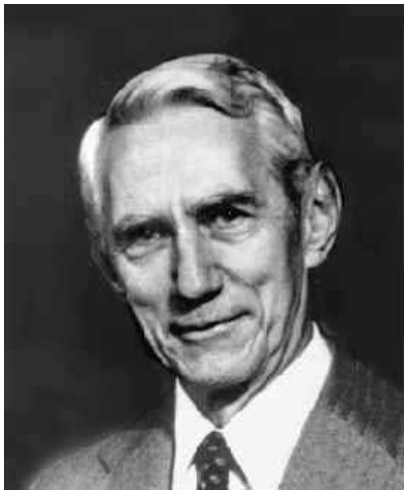
Boston. – Der Mathematiker und Computerwissenschafter Claude Elwood Shannon ist am Samstag 84-jährig gestorben. Shannon hatte in den 30er-Jahren den so genannten Binärcode entwickelt, der noch heute als Eckpfeiler der Computerwissenschaft gilt. Shannon prägte in seinen Thesen den Begriff «Bit» für die kleinste Informationseinheit. Shannon legte zudem den Grundstock für die Kryptografie, die Mathematik der Wahrscheinlichkeit und mehr. Selbst die jüngsten Erfolge bei der Entschlüsselung des menschlichen Erbguts wären ohne seine Ideen nicht denkbar. *(SDA)*

Tages-Anzeiger · Mittwoch, 28. Februar 2001

Claude Shannon 1916 - 2001
The Father of Information Theory

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

- Information Theory
  - Worked at MIT / Bell Labs
  - „The Mathematical Theory of Communication“ (1948)
  - Maximum capacity of a noisy transmission channel
  - Definition of the „binary digit“ (bit) as a unit of information
  - Definition of „entropy“ as a measure of information
- Cryptography
  - Model of a secrecy system
  - Definition of perfect secrecy
  - Basic principles of „confusion“ and „diffusion“



Basic Principles of „Confusion“ and „Diffusion“

• Throughout history the principles of „confusion“ and „diffusion“ have been used in innumerable codes and ciphers. Shannon was the first to formulate these two principles explicitely, „**confusion**“ standing for **substitution** operations and „**diffusion**“ standing for transposition or **permutation** operations. These two principles are still actively used in modern ciphers.

Mary Stuart 1516 - 1558

Famous Victim of Successful Cryptanalysis

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL



Mary Stuart
Queen of Scotland



Elizabeth I
Queen of England

Codes have decided the fates of empires throughout recorded history

- Mary Stuart, Queen of Scotland was put to death by her cousin Queen Elizabeth of England, for the high crime of treason after spymaster Sir Francis Walsingham cracked the secret code she used to communicate with her conspirators.

Source: Simon Singh, „The Code Book“, Doubleday, 1999

Shannon's Principle of Confusion
Caesar Monoalphabetic Substitution Cipher

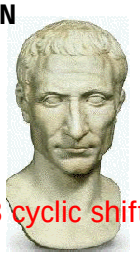
HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

MESSAGE FROM MARY STUART KILL THE QUEEN

Substitution Table - Caesar's Cipher

ABCDEFGHIJKLMNOPQRSTUVWXYZ

DEFGHIJKLMNOPQRSTUVWXYZABC ← key = 3 cyclic shifts



PHVVD JHIUR PPDUB VWXDU WNLOO WKHTX HHQ

General Substitution Table

ABCDEFGHIJKLMNOPQRSTUVWXYZ

EYUOBMDXVTHIJPRCNAKQLSGZFW ← 26! possible keys

JBKKE DBMAR JJEAF KQLEA QHVII QXBNL BBP

Andreas Steffen, 17.10.2005, 2-Cryptology.ppt 12

Caesar Cipher

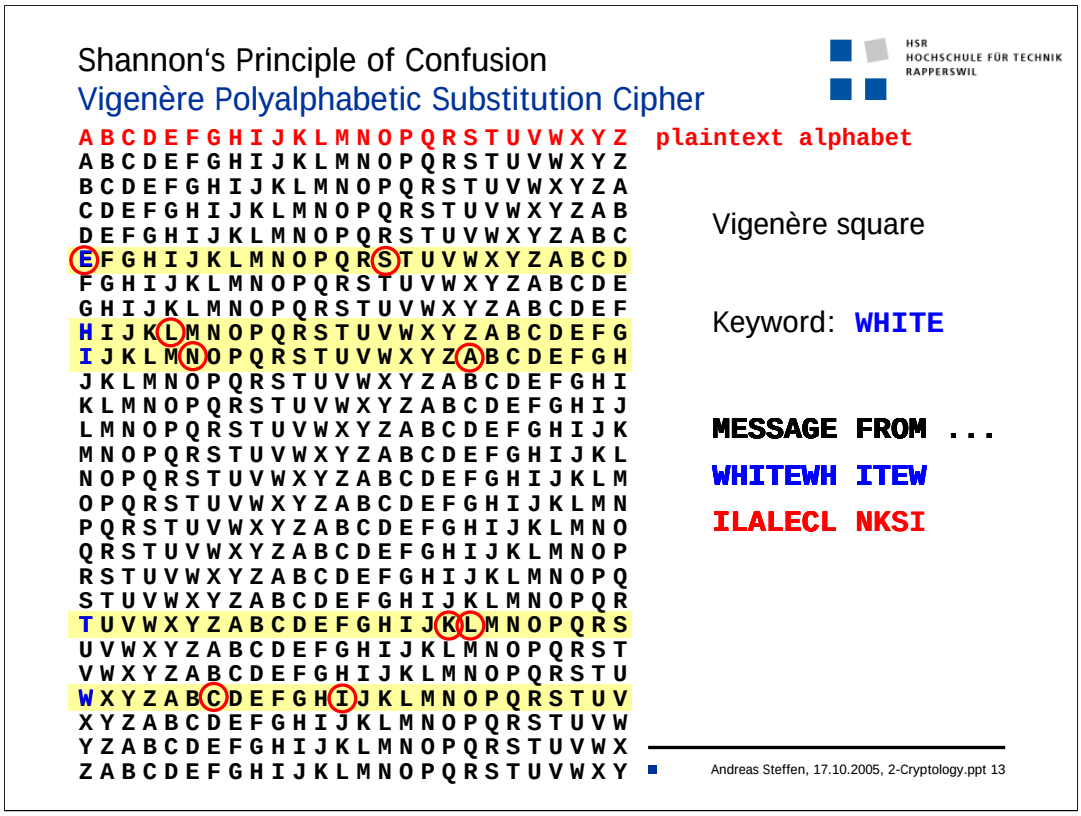
- The famous cipher used by Julius Caesar during his campaigns replaced each plaintext character by the character cyclicly shifted to the left.

  "A" is replaced by "D", „B" by „E" and finally „Z" by „C".

  This is a simple **monoalphabetic substitution cipher,** where each character in an alphabet is replaced by another character in the same alphabet or sometimes even by a symbol of a different alphabet. With an alphabet of 26 characters and the most general substitution table there exist an enormous number of 26! different keys. This seems to make this system quite secure.
- Unfortunately monoalphabetic substitution schemes suffer from the severe drawback that with a given key, each occurence of a specific plaintext character is always mapped to the same ciphertext character, thus preserving the well-known character count statistics of natural language plaintexts, on the basis of which ciphertexts can be cracked quite quickly.

Substitution using S-Boxes

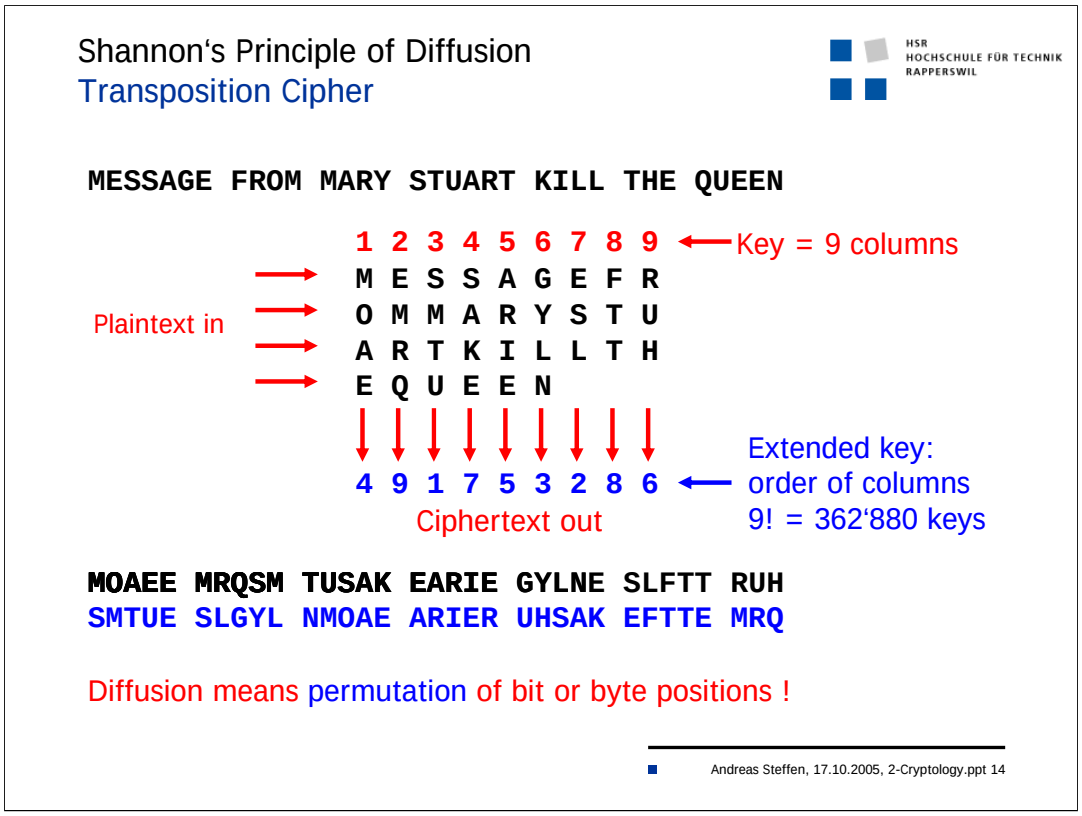
- In modern ciphers a fixed number of plaintext bits are grouped together and are substituted by a different bit combination according to a fixed lookup table.
- A software or hardware module which implements this substitution operation is called an **S-Box**.



Vigenère Cipher

- Blaise de Vigenère, a French diplomat born in 1523 invented a substitution cipher that for a long time was thought to be unbreakable. The strength of the Vigenère cipher lies in its using not one, but 26 distinct cipher alphabets to encrypt a message. The first step in encipherment is to draw up a so-called Vigenère square, a plaintext alphabet followed by 26 cipher alphabets, each shifted by one letter with respect to the previous alphabet. A secret keyword determines which alphabet is used in which order. Since subsequent characters of plaintext are coded with different alphabets, a certain plaintext character is mapped to several ciphertext characters. The use of this polyalphabetic substitution effectively smears the characteristic statistics of natural language text.
- The Vigenère cipher can be broken because of the period reuse of the keyword. If a common sequence like e.g.the word „the“ occurs again after a multiple of the keyword length, then it will be mapped to the same plaintext. As soon as the length of the keyword has been determined, a frequency analysis can be effected on each individual alphabet.

Source: Simon Singh, „The Codebook“



Classical Transposition Cipher

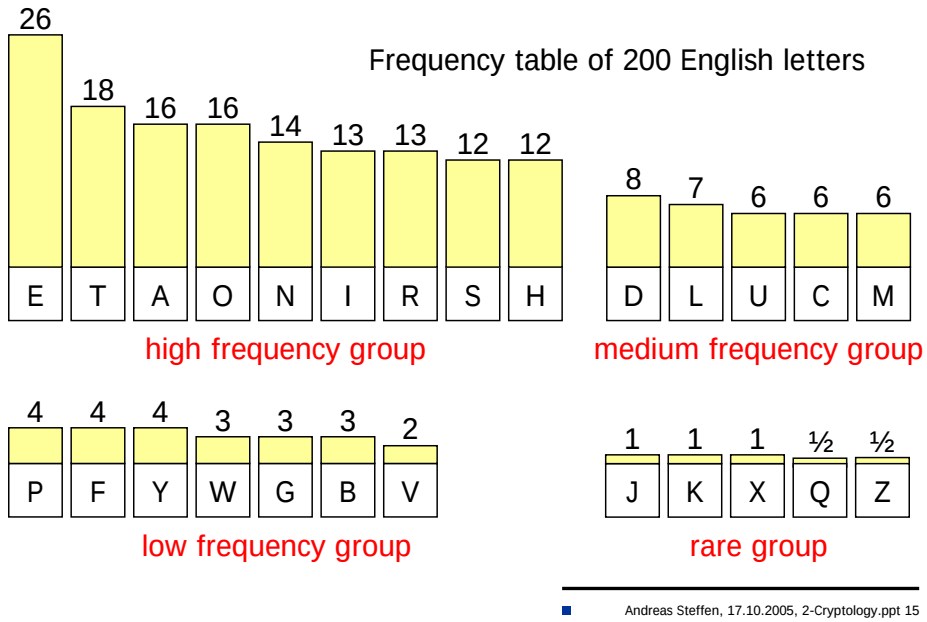
- In a classical transposition cipher the plaintext is written on a piece of paper in horizontal rows of *c* characters each. The number of columns *c* is part of the secret key. After the whole text has been written down in this fashion, the ciphertext is read out vertically column after column. In simpler versions this is done in increasing column order, but in a generalized method the columns could be chosen in any order (known of course by the authorized receiver) thereby extending the number of possible keys.

Permutation using P-Boxes

- In modern ciphers a fixed number of bits are written in linear order into a buffer and are read out in a permuted order controlled by a fixed lookup table.
- A software or hardware module which implements this permutation operation is called a **P-Box**.

Most Cryptoanalytic Attacks base on the Redundancy of Natural Language Texts

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL



Georges Perec, „La disparition“, 1969
Book of 280 pages without a single letter e

HSR
HOCHSCHULE FÜR TECHNIK
RAPPERSWIL

...Anton Voyl n'arrivait pas à dormir. Il alluma. Son Jaz marquait minuit vingt. Il poussa un profond soupir, s'assit dans son lit, s'appuyant sur son polochon. Il prit un roman, il l'ouvrit, il lut ; mais il n'y saisit qu'un imbroglio confus, il butait à tout instant sur un mot dont il ignorait la signification. Il abandonna son roman sur son lit. Il alla à son lavabo ; il mouilla un gant qu'il passa sur son front, sur son cou. Son pouls battait trop fort. Il avait chaud...



Excerpt from „La disparition“ © Editions Denöel

Entropy of the English Language

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

- Single character statistics
  - Entropy H = 4 bits / character
- Written English taking into account the full context
  - Shannon (1950): Entropy H = 0.6 ... 1.3 bits / character
  - Simulations (1999): Entropy H = 1.1 bits / character
- What about the entropy of C source code?

```
for (c = 0; c < 256; c++) {
  i2 = (key_data_ptr[i1] + state[c] +  i2) % 256;
  swap_byte(&state[c], &state[i2]);
  i1 = (i1 + 1) % key_data_len;
}
```

- Compression before encryption increases security
  - Good data compression algorithms (e.g. Lempel-Ziv) remove all redundancy and come very close to the entropy of the plaintext.

Single Character Entropy

• By counting the number of occurences of each character c_i in a multitude of English texts the single character probabilities $p(c_i)$ can be determined. Over the whole alphabet these probabilities must add up to one.

$$\sum_{i=1}^{26} p(c_i) = 1$$

• The entropy can now be computed with the following formula

$$H = \sum_{i=1}^{26} p(c_i) \cdot \log_2 \frac{1}{p(c_i)}$$

• With the statistical values from the previous page the single character entropy becomes H = 4.19 bit, which is about half the 8 bit ASCII representation requires.

Random Passwords with 128 Bits of Entropy

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL

- Digits (0..9): 39 digits ∗ 3.3 bits/digits
  - **39475 10485 98021 43380 05872 49759 70291 2634**
- Hexadecimal (0..F): 32 nibbles ∗ 4 bits/nibble
  - **3F8A 84D1 EA7B 5092 C64F 8EA6 73BD F01B**
- Alphabet (A..Z): 28 characters ∗ 4.7 bits/character
  - **AWORH GHJBP IUCMX MLZFQ TZDOP ZJV**
- Alphabet & Digits (A..Z, 0..9): 25 symbols ∗ 5.2 bits/symbol
  - **E5RGL UPQ7A 8F3ZP NWTIC 22JBM**
- Base64 (A..Z, a..z, 0..9, /, +): 22 symbols ∗ 6 bits/symbol
  - **y5GNa Riq92 VCm4Q 1BOKl x0**

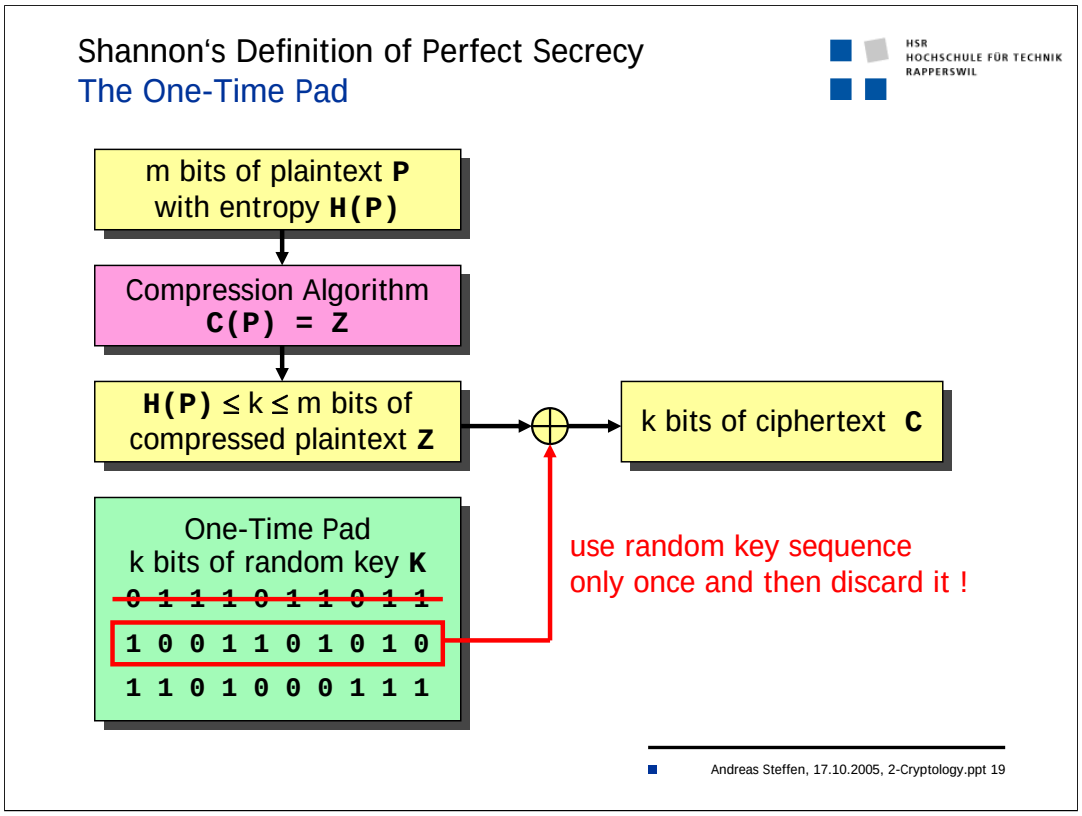
Entropy of random passwords

• If we assume that each symbol in a given set of symbols occurs with the same probability then the entropy per symbol can computed with the following formula:

Entropy/symbol = $\log_2$ (Number of symbols in set) [bits/symbol]

• Example: Set of 16 hexadecimal symbols: 0..9, A..F:

Entropy/symbol = $\log_2$ (16) = 4 bits/symbol

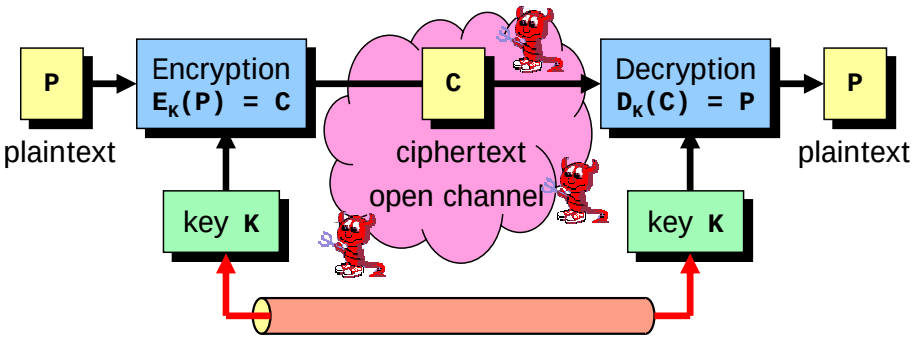


Perfect Secrecy

- Shannon has proven, that if correctly applied, the **one-time pad** becomes a **perfectly secure cryptosystem**.
- The plaintext is first reduced as close as possible to its true entropy by feeding it into a good compression algorithm. If ideal compression could be achieved, then changing any number of bits in the compressed message would result in another sensible message when uncompressed.
- The compressed plaintext is next XOR-ed bit-by-bit with random bits taken from the one-time pad, thus forming a perfectly random ciphertext. Once used these key bits must be discarded from the one-time pad and never used again.
- Without the correct key sequence it is impossible to retrieve the original plaintext since applying any other key of the same length would also give a sensible plaintext message after uncompression.
- **Why are one-time pads used only by secret agents and e-banking customers?** The secure distribution of the required keying material would pose an an enormous logistical problem if the one-time-pad were used on a large scale!

Shannon's Model of a Secrecy System
Symmetric or Secret-Key Cryptosystems

HSR HOCHSCHULE FÜR TECHNIK RAPPERSWIL



- Same key used for encryption and decryption
- Key must be kept absolutely secret
- Same key can be used for several messages, but should be changed periodically → secure key distribution problem!